

CircuLink 管理员权限与审核指导文件

1. 文档目的

本文档用于定义 CircuLink 的账号角色、管理员权限、审核流程、数据访问边界和数据库设计建议。

适用范围包括：

- 二手交易 listing
- Donation 捐赠 listing
- club-operation 运营流程
- Buy42 / 合作方接收流程
- 管理员审核与数据治理
- AI 辅助审核与人工审核边界

目标是在保护 DKU 社区安全的同时，尽量减少对个人数据的访问和暴露。

2. 账号角色

CircuLink 建议支持四种主要账号类型。

角色	核心定位	主要用途
USER 普通用户	平台普通用户	买卖、捐赠、领取、站内沟通
CLUB_OPERATOR club-operation 成员	学生组织 / 运营账号	审核 donation、线下收集、捐赠协调
BUY42_PARTNER Buy42 / 合作方账号	合作接收方账号	查看被分配的 donation 描述信息，并选择是否接受
ADMIN 管理员	平台管理员	管理用户、角色、listing、审核、数据导出和系统治理

3. 权限设计原则

CircuLink 应遵循以下原则：

- 默认采用最小权限原则。

- 每种角色只能访问完成其职责所需的数据。
- 二手交易数据和 donation 运营数据应分离管理。
- 默认不开放私聊内容，除非涉及举报、争议或安全调查。
- 默认不展示完整用户身份信息，除非业务确实需要。
- 不向合作方共享原始个人数据。
- 所有管理员和合作方操作都应可审计。
- AI 可以辅助审核，但最终处罚和争议处理应由人工负责。
- 研究数据默认应匿名化或汇总化，除非已有明确 consent / IRB 批准。

4. 功能权限矩阵

功能	Admin 管理员	club-operation	普通用户	Buy42 合作方
买二手物品	可以	可以	可以	不可以
发布二手 listing	可以	可以	可以	不可以
发布 donation	可以	可以	可以	不可以
上传图片	可以	可以	可以	不可以
站内发消息	可以	可以	可以	仅限已分配 donation 交接场景
查看自己的 listing	可以	可以	可以	不可以
查看 donation 清单	全部	仅运营相关	仅自己的 donation	仅被分配的待接收 / 已接收 donation
选择是否接受 donation	可以	可协助	不可以	可以
审核 listing	可以	仅 donation 相关	不可以	不可以
隐藏或归档违规 listing	可以	可协助或标记	仅自己的 listing	不可以
管理用户角色	可以	不可以	不可以	不可以
导出研究数据	可以，但受限制	不可以	不可以	不可以
查看审计日志	可以	仅必要的本人操作日志	不可以	不可以
查看私聊内容	仅特殊情况	不可以	仅自己的聊天	不可以

5. 数据访问矩阵

数据类型	Admin 管理员	club-operation	普通用户	Buy42 合作方
商品标题 / 描述 / 价格 / 分类	全部	仅运营相关	自己的和公开 active listing	不可以
Donation 图片 / 文字描述 / 捐赠类别	全部	相关 donation 记录	自己的和公开 active donation	仅被分配 donation 的描述信息
用户邮箱 / NetID / 真实姓名	仅必要情况	仅交接必要时	仅自己的资料	不可以
联系方式	仅必要情况	最小必要字段	仅自己的信息	不可以
交易记录	全部，但需留日志	不查看二手交易数据	仅自己的交易	不可以
Donation 交接记录	全部	相关记录	自己的 donation 记录	被分配记录
私聊消息	仅特殊情况	不可以	仅自己的消息	不可以
AI 审核结果	全部	仅 donation 相关结果	不可以	不可以
审计日志	全部	必要时查看本人操作日志	不可以	不可以
研究数据导出	默认匿名化 / 汇总化	不可以	不可以	不可以

6. 发布与编辑策略

CircuLink 第一个稳定版本建议采用更简单、更安全的规则：

> 已通过审核的 listing 和 donation 不允许直接编辑核心内容。用户只能下线、标记 sold / claimed，或重新提交一个新的 listing。

审核通过后允许：

- 将二手 listing 标记为 SOLD
- 将 donation 标记为 CLAIMED、RESERVED，或根据流程继续推进
- 归档 / 下线自己的 listing
- 如需修改内容，提交新的 listing 或 donation

审核通过后不允许：

- 修改标题
- 修改描述
- 修改价格
- 修改分类
- 替换或新增图片
- 修改 donation 条件

- 将 donation 改成收费 listing

这样可以避免用户先发布安全内容通过审核，再修改成高风险内容来绕过审核。

7. 审核流程

7.1 新发布二手 listing

- 1 用户提交新的二手 listing。
- 2 系统检查必填字段、分类、价格、图片数量和基础内容规则。
- 3 AI 对文本和图片做风险预审。
- 4 决策引擎分流：
 - 低风险：直接显示在网页，减少人工介入
 - 被规则或 AI 标记：进入人工审核
 - 高风险：先隐藏并等待审核
- 1 人工审核员决定通过、拒绝、要求修改或归档。
- 2 用户收到明确的审核结果和原因。

7.2 新发布 donation

Donation 应比普通二手 listing 更严格。

- 1 用户提交 donation。
- 2 系统执行 donation 专属规则。Donation 页面只包含图片、文字描述和捐赠类别，默认不存在价格字段。
 - 不允许押金、付款、外部转账或变相售卖。
 - 必须提供必要的领取 / 交接信息。
- 1 AI 检查不安全物品、可疑描述、图片不匹配和私下付款信号。
- 2 低风险 donation 可以通过。
- 3 被规则或 AI 标记的 donation 进入 Admin 或 club-operation 审核。
- 4 club-operation 可以直接 approve donation。
- 5 审核通过后，donation 可公开展示或进入线下收集流程。

7.3 已有 listing 或 donation

用户不应直接编辑已通过审核的核心内容。

如果用户想修改核心内容：

- 1 先归档当前 listing / donation。
- 2 提交新的 listing / donation。
- 3 新提交内容重新走正常审核流程。

这可以让审核模型更简单、更可追溯。

8. 审核决策规则

场景	建议处理
信息完整、低风险的二手 listing	自动通过并直接显示
图片清晰、无付款暗示的低风险 donation	自动通过或由 club-operation 直接 approve
缺少必填字段	阻止提交，并要求用户补充
Donation 描述中出现押金、换物、付款或私下转账	人工审核，通常应拒绝
高价值电子产品	人工审核
食品、药品、化妆品、电池、尖锐工具或不安全物品	人工审核
外部付款、二维码、站外交易话术	先隐藏，等待审核
同一用户重复发布可疑内容	升级给 Admin
明显违规内容	立即隐藏，并由 Admin 最终处理

9. AI 与人工审核边界

AI 应负责：

- 风险评分
- 文本和图片预筛
- 分类与图片一致性检查

- 诈骗、外部付款和不安全物品识别
- 给人工审核员生成摘要

AI 不应负责：

- 最终封禁账号
- 最终严重处罚
- 对模糊案例直接最终拒绝
- 私人数据导出决策

人工审核应负责：

- 最终拒绝
- 账号警告或限制
- 争议处理
- 申诉处理
- 敏感品类判断
- 涉及隐私数据或合作方权限的决策

10. 状态模型

推荐的二手 listing 状态：

DRAFT
PENDING_REVIEW
ACTIVE
NEEDS_CHANGES
REJECTED
SOLD
ARCHIVED
HIDDEN

推荐的 donation 状态：

DRAFT
PENDING_REVIEW
ACTIVE
RESERVED
CLAIMED
COLLECTED_BY_CLUB

RECEIVED_BY_BUY42
DONATED
REJECTED
ARCHIVED
HIDDEN

Donation workflow 应独立成表，不建议长期复用 marketplace 的 Item 表。实现上可以保留通用图片上传能力，但 donation 主数据、状态流转和交接记录应独立建模。

11. 数据库设计建议

11.1 角色表

当前 schema 中已有 `User.role`。MVP 可以继续使用，但长期建议增加角色历史表。

推荐表：

`user_roles`

建议字段：

- `id`
- `user_id`
- `role`
- `granted_by`
- `granted_reason`
- `expires_at`
- `revoked_at`
- `created_at`
- `updated_at`

这样可以支持 club-operation 和 Buy42 临时权限，到期后自动失效。

11.2 审核队列表

推荐表：

`review_queue`

建议字段：

- id
- target_type: listing / donation / image / user
- target_id
- submission_type: new_listing / new_donation
- submitted_by
- status: pending / approved / rejected / needs_changes / hidden / escalated
- risk_level: low / medium / high
- ai_summary
- ai_flags
- assigned_reviewer_id
- reviewed_by
- review_reason
- created_at
- reviewed_at
- updated_at

因为 MVP 不允许已审核内容直接编辑，所以暂时不需要复杂的新旧版本 diff 表。人工审核只处理被系统规则或 AI 标记的内容；低风险发布原则上直接显示。

11.3 审核决策表

推荐表：

review_decisions

建议字段：

- id
- review_id
- decision: approve / reject / request_changes / hide / escalate
- reviewer_id
- reason_code

- comment
- created_at

该表用于保留“谁在什么时候为什么做出该审核决定”。

11.4 AI 审核结果表

推荐表：

ai_review_results

建议字段：

- id
- review_id
- model_name
- risk_score
- risk_level
- flags
- summary
- raw_output
- created_at

raw_output 可能包含用户提交内容，访问权限应受限制。

11.5 管理员审计日志表

推荐表：

admin_audit_logs

建议字段：

- id
- actor_id
- actor_role
- action

- target_type
- target_id
- before
- after
- ip_address
- user_agent
- created_at

必须记录：

- 角色分配或撤销
- 审核决定
- listing 隐藏 / 归档 / 删除
- donation 状态变更
- Buy42 确认收件
- 查看敏感数据
- 数据导出

11.6 数据导出日志表

推荐表：

data_export_logs

建议字段：

- id
- exported_by
- export_type
- fields_included
- anonymized
- purpose
- approved_by

- created_at

数据导出默认应匿名化。

11.7 Donation 交接表

推荐表：

donation_handovers

建议字段：

- id
- donation_id
- club_operator_id
- buy42_account_id
- handover_status
- pickup_time
- handover_location
- received_at
- receipt_image_url
- notes
- created_at
- updated_at

Buy42 应访问专门的交接视图，而不是完整管理员后台。Buy42 只能看到 donation 的图片、文字描述、捐赠类别和必要交接状态，并选择是否接受；不能看到用户联系方式。

12. Admin 安全管控

敏感管理员操作应有更强管控：

- 角色修改必须要求 Admin 权限。
- 分配另一个 Admin 只需要一个现有 Admin 批准，但必须记录审计日志。
- 数据导出必须填写目的，并记录审计日志。

- 删除或隐藏 listing 必须记录原因。
- 查看敏感用户身份字段必须记录日志。
- 私聊内容默认不可见；只有存在现有用户举报、争议或安全事件时才允许查看，并必须记录日志。
- Buy42 账号不得访问通用 admin 后台。
- club-operation 账号不得访问数据库、服务器、GitHub secrets 或完整用户导出。
- 临时账号应自动过期。

13. 用户通知规则

用户应收到明确状态通知：

- 已提交审核
- 审核通过
- 审核拒绝及原因
- 需要修改
- 因安全原因暂时隐藏
- Donation 已预约 / 已领取 / 已交接 / 已接收

通知应足够具体，让用户知道如何修改，但不应暴露完整风控规则。

14. 申诉与争议处理

CircuLink 应支持基础申诉流程：

- 用户可以对被拒绝或被隐藏的 listing 提交申诉。
- 申诉应进入 Admin 审核，而不是只由 AI 处理。
- Admin 可以维持原决定、撤销决定或要求修改。
- 所有申诉决定都应记录日志。

15. 实施 Todo List

Phase 1: MVP 权限治理

- □ 确定角色名称：USER、CLUB_OPERATOR、BUY42_PARTNER、ADMIN。
- □ 在后端校验中加入这些角色值。
- □ 决定 MVP 阶段继续使用单一 User.role，还是新增 user_roles。
- □ 定义 listing 和 donation 状态。
- □ 阻止用户编辑已审核通过内容的核心字段。
- □ 允许用户归档、标记 sold，或重新提交新 listing。
- □ 在 listing / donation 创建流程中加入 review status。
- □ 创建 Admin 审核后台，用于查看被规则 / AI 标记的 pending listing 和 donation。
- □ 增加用户可见的审核状态提示。

Phase 2: 审核系统

- □ 新增 review_queue。
- □ 新增 review_decisions。
- □ 定义 approve / reject / request changes / hide 的原因码。
- □ 将被规则 / AI 标记的新发布二手 listing 接入人工审核流程。
- □ 将被规则 / AI 标记的新 donation 接入人工审核流程。
- □ 允许 Admin 审核、拒绝或隐藏任何审核项。
- □ 允许 club-operation 直接 approve donation。
- □ 禁止 Buy42 审核平台内容。

Phase 3: 合作方与 Donation 交接流程

- □ 新增 donation_handovers。
- □ 构建 club-operation donation 运营视图。
- □ 构建 Buy42 限制版交接视图。
- □ 允许 Buy42 查看被分配 donation 的描述信息、类别和图片，并选择是否接受。
- □ 禁止 Buy42 查看用户联系方式。
- □ 记录 Buy42 收件确认日志。
- □ 防止 Buy42 查看二手交易记录或完整用户画像。

Phase 4: AI 辅助审核

- □ 定义 AI 审核输入字段。
- □ 定义 AI 输出 schema : risk score、risk level、flags、summary。
- □ 新增 ai_review_results。
- □ 使用 AI 预筛新 listing 和 donation。
- □ 只对明确低风险内容自动通过。
- □ 将中高风险内容交给人工审核。
- □ 禁止 AI 单独执行封禁或严重处罚。

Phase 5: Admin 安全与审计

- □ 新增 admin_audit_logs。
- □ 记录角色变更。
- □ 记录审核决定。
- □ 记录 listing 隐藏 / 归档 / 删除。
- □ 记录敏感数据查看。
- □ 记录数据导出。
- □ 对数据导出增加二次确认 ; Admin 分配由一个现有 Admin 批准并记录日志。
- □ 给 club-operation 和 Buy42 账号增加权限过期时间。
- □ 增加定期权限复核流程。

Phase 6: 研究数据治理

- □ 定义可导出的研究字段。
- □ 默认导出移除直接身份标识。
- □ 新增 data_export_logs。
- □ 要求填写导出目的。
- □ 非匿名化导出必须要求 Admin 批准。
- □ 记录 consent / IRB 要求。

16. 已确认产品决策

- 只有被系统规则或 AI 标记的内容需要进入人工审核；低风险发布原则上直接显示在网页。
- REACH_OPERATOR 不再使用，改为 CLUB_OPERATOR / club-operation。
- club-operation 可以直接 approve donation。
- Donation 页面只包含图片、文字描述和捐赠类别，本身没有价格字段。
- Buy42 不能看到用户联系方式；只能看到 donation 描述信息、类别、图片和交接状态，并选择是否接受。
- 查看私聊内容必须基于现有用户举报、争议或安全事件。
- 分配 Admin 只需要一个现有 Admin 批准，但必须记录审计日志。
- Donation workflow 独立成表，不与 marketplace listing 长期共用 Item 表。